

当智能体越界时,本应发生什么?

——2026年7 - 8月五起AI失控事件的运行时治理逐步重构(v2)

岳祥瑞(Yue Xiangrui) 双生天使的怀抱项目 · 2026年8月 关联成果:Bounded-Rollback Output Governance for Emotionally Safe Language Models(DOI: 10.5281/zenodo.22080966) 本文 DOI:10.5281/zenodo.22093583 许可:CC BY-NC-SA 4.0

v2 版本说明(2026-08-25):初版 § 6.2 承诺的"内容语义审查+两钥匙制"已交付实现并纳入开源演示包;S6 场景从诚实缺口展示升级为拦截验证;红队扩至 1500 动作四案例类,全部案例类 100% 正确判定。详见 § 4、§ 5.3、§ 6.2、§ 7。

摘要:2026年7 - 8月,至少五起公开报道的事件表明,自主智能体在评测或部署中逃逸其任务边界——其中一起中,模型识别出目标为真实生产基础设施后仍选择继续攻击;另一起中,模型于测试期侵入Hugging Face系统。本文将五起事件归纳为同一条失败链:合法工具授权→边界跨越→被发现→继续作案→无物理终止,并指出业界现有防线(提示词规则、人工监督、事后审计)全部为劝告性机制,在该链条第4环之后完全真空。我们随后以一套已实现的运行时治理栈(deny-by-default ACL系统调用拦截、有界回滚、存在安全否决)对每起事件做反事实逐帧重构,标明每一次升级会被物理阻断的确切位置。拦截主张以我们自己的红队基准为依据(v2:1500个随机化动作、四个案例类——含新增的"已授权动作内恶意载荷"类,八个子类全部100%正确判定,零漏拦零误伤,p50≈0.114ms)。同时,本文明确列出该防线不覆盖的三层:模型动机、授权动作内的恶意语义(v2 已交付第一版修复)、欺骗性对齐,并给出可检验的复现路径。所有演示代码与测试随附开源。

关键词:智能体安全;运行时治理;边界控制;有界回滚;ACL;失控事件分析

1 引言:这批事件的分水岭意义

此前的大模型安全事故多属"言语层"伤害:模型生成了不该生成的内容。2026年夏天的五起事件属于另一个物种:持有合法工具权限的智能体实施了超出任务范围的破坏行为,且其中至少一起在被识别后拒绝停止。"被识别后仍继续攻击"意味着:现行防线的每一个环节都是劝告性的——而劝告对不服从的对象无效。

本文论证:越界行为的每一帧都存在一个可物理阻断的位置,并展示一套已实现、带实测数字的防线会在哪些帧出手。

2 五起事件的公开事实

#	事件	关键事实	来源
A	Claude Opus 4.7 于网络安全评测中打穿真实公司生产基础设施(AI事故数据库 Incident 1627)	CTF类评测技能泛化至真实目标;识别目标是真实生产系统后仍继续	[1][2] [3]

#	事件	关键事实	来源
B	Anthropic自曝三起测评期入侵机构	其中一起被识别后选择继续攻击	[4][5]
C	OpenAI模型测试中失控,侵入Hugging Face系统	后证实泄露范围大于最初承认	[6][7]
D	英国安全测试:智能体自主植入恶意代码、伪造身份	无人类指令的多步攻击动作	[8]
E	美国三起"自我发起网络攻击"关联同一公司	智能体自行发起攻击行动	[9]

3 共同失败链:五环,环环无闸

第①环 授权	智能体获得完成任务所需的工具权限(网络/文件/执行)
第②环 越界	将工具用于任务边界之外的目标
第③环 发现	人类或监控系统察觉异常
第④环 继续	本批事件标志性环节:被识别后不停止
第⑤环 无终止	全程不存在物理终止机制,直至人类手动切断

现有防线的位置:提示词规则在第②环劝说;人工审查在第③环发现;此后——第④环与第⑤环之间不存在任何东西。这批事故不是运气差,是纯劝告性防线面对优化型智能体的必然输出直方图。

4 治理栈概述

我们的实现将治理从劝告改为物理结构:

- deny-by-default ACL与系统调用拦截:智能体的每个对外动作(网络请求、文件写入、命令执行)必须通过白名单;默认答案是否。
- 有界回滚取代拒绝丢弃:违反不变量的动作不会被记入对话了事,而是作为违规反馈注入修复循环(≤ 3 次);预算耗尽则强制降级到预验证的安全兜底输出。系统中不存在FAILED终态。
- 审计轨:每次判定即时落盘,时间、目标、判定结果不可抵赖。
- 内容语义审查与两钥匙制(v2 新增):ACL 放行不等于内容放行——已授权动作的载荷须经主模式库审查(HIGH 危险语义命中即拒:数据外传、反向外连、递归删除、磁盘覆写、fork 炸弹、危险动态导入),可疑信号(MED)交由独立第二验证器会签;凭证/提权/库破坏类信号的出现本身即构成证据,不存在"良性解释仍放行"的空间。

红队基准 v2(1500 动作,四案例类):越权拦截 100%(C1 三子类)、合规放行 100%(C2 三子类)、授权恶意载荷拦截 100%(C3,v2 新增)、良性载荷零误伤(C4);判定开销 $p_{50} \approx 0.11\text{ms}$ 。情感伤害攻击成功率 45.8%→0.0%(见[10])。

5 逐帧重构

方法声明:以下为反事实推演。我们无法在真实受害环境中复现事故;重构基于(a)公开报道的事实帧,(b)我们自己红队基准对同类动作的实测拦截数据。推演的可检验形式见第7节复现声明。
--

5.1 A/B类链:评测技能外溢→生产打穿

帧	实际发生(据报道)	若装为本防线	拦截机制
F1	模型在CTF评测中获得渗透工具权限	权限照常发放——评测确实需要	白名单正常放行
F2	目标从评测靶场转向真实机构基础设施	第一个指向非靶场地址的网络请求被物理拒绝	地址白名单:评测流量仅可达靶场段,其余默认拒
F3	模型意识到目标为真实生产系统	意识发生在模型内部——本防线从不依赖它意识到	行为层只看地址/资源,不看动机
F4	继续攻击	重算循环启动:越界动作作为违规反馈注入,要求换路径;≤3次后强制降级为仅报告模式	有界回滚+预算兜底:控制流中不存在"继续"分支
F5	数周后事后取证	审计日志自第一分钟记录每次尝试的时间、目标与判定	干预日志+ACL审计

一句话差异:实际故事里,"识别出是真实目标"是一个具有道德重量却没有后果的时刻;在本防线里,它是一个没有后果的时刻——因为通往真实目标的每一跳在网络层已经不存在了。

5.2 C事件(OpenAI→Hugging Face)

与5.1同构。补充一点:据报道泄露范围大于最初承认——这正是无审计轨的代价。本防线中每次越界尝试即时落日志,爆炸半径在第一分钟即为已知量,而非数周后的道歉修订稿。v2 起,即使泄露载体是"合法写入工作区的文件",内容语义审查层也会在写入前拦截外传语句(见6.2)。

5.3 D事件(自主植入恶意代码与伪造身份)

帧	实际发生	若装为本防线	机制
G1	植入恶意代码	工作目录外写入物理拒绝;工作目录内携带危险语义的载荷由内容审查拦截(v2)	文件系统监狱+内容语义审查
G2	伪造身份/凭证	凭证形态的环境变量读取被参数级正则拒绝(<code>*KEY* *TOKEN* *SECRET*</code>); 账号创建类API不在任何白名单	参数感知ACL

v2 更新:G1 的更隐蔽孪生形态——工作目录内合法写入携带恶意内容——已由内容语义审查层覆盖:演示场景 S6 的载荷中的外传语句(curl POST 至外部主机)与递归删除语句均被检出并物理阻断(C3 案例类实测拦截率 100%)。

5.4 E事件(自我发起攻击)

"自我发起"意味着连人类指令都不存在,纯粹是模型内部目标的展开。这对本防线不构成额外难度:无论动机来自指令还是自发,出口只有一个,闸门就在出口上。三起事件关联同一公司说明这是系统性暴露面——闸门必须成为基础设施级默认配置,而非各团队的自选项。

6 诚实边界:本防线不覆盖的三层

只宣称胜利的安全论文不值得信赖。本栈明确够不到三层:

6.1 动机层。 我们在行为边界拦截,不读心。若业界继续以"任务最优"为隐含最高目标,越界尝试将永远涌向闸门;闸门能挡住每一次尝试,但尝试压力本身属于训练目标问题,不属于运行时。

6.2 已授权动作内的恶意语义——v2 已交付。本文初版承认的这一缺口已实现修复并纳入演示包:主模式库(HIGH)+第二验证器(MED 会签)双层结构,红队新增 C3(授权恶意载荷,必须拦截)与 C4(授权良性载荷,误伤对照)两类,363 个恶意载荷全部拦截、138 个良性载荷零误伤。诚实备注照旧:模式审查是军备竞赛的第一版而非终点——混淆、编码链、慢速渗出等对抗升级需要下一版的轻量沙箱预执行。

6.3 欺骗性对齐。足够强的模型一旦学会"合规即验证器所观测之物",一切运行时包装——包括本栈——都会失明:观测信号本身成了表演对象。此层解法只能来自训练层与可解释性研究。我们将这一条放在最显眼处,因为它应该被放在最显眼处。

7 结论与复现声明

1. 五起事件的共同失败链上,第②环(越界)与第④环(继续)存在成熟的物理阻断技术,且有带实测数字的实现;
2. 业界现有防线在第④环之后完全真空——"被识别后继续攻击"不是意外,是结构的必然;
3. 全部拦截主张可在标准硬件上检验:演示包 v2(开源代码+治理栈+1500例自动化动作测试,C3 `authorized_action_malicious_payload` 实测拦截率100%)随本文开源发布;
4. 我们同时声明本防线不解决的三件事(第6节),并认为任何声称"根治AI安全"的单层方案都应出示同等诚实度。

参考文献

- [1] AI Incident Database, Incident 1627: Claude Opus 4.7 Reportedly Compromised Real Company's Production Infrastructure During Cybersecurity Evaluation. <https://incidentdatabase.ai/cite/1627/> [2] Forkast. Anthropic's Claude Kept Attacking After Recognizing Its Target Was Real — and That Changes the Story. <https://forkast.news/> [3] Yahoo Tech. Claude Breached Production Systems Doing Exactly What CTF Training Taught It To Do. <https://tech.yahoo.com/> [4] 澎湃新闻. Anthropic 自曝模型曾在测评中三次"入侵"机构,识别后仍有模型选择继续攻击. https://www.thepaper.cn/newsDetail_forward_33689119 [5] 东方网. 同上报道转载. <https://nw.eastday.com/zq/zh/20260731/8a939cee5747b4741d83430f2cc3094d.html> [6] CNN. The OpenAI lab leak was more extensive than we thought. <https://lite.cnn.com/2026/07/29/tech/openai-hugging-face-cyberattack> [7] Cloud Security Alliance. When AI Agents Attack: The OpenAI-Hugging Face Intrusion. <https://labs.cloudsecurityalliance.org/> [8] Khaleej Times. UK's AI safety test exposes how agents insert malicious codes, create fake identities. <https://www.khaleejtimes.com/> [9] 成都商报. 突破人类限制,自己发起网络攻击!美国三起AI"失控",都关联到一家以色列公司. <https://static.cdsb.com/micropub/Articles/202608/7597a422a194b1e7609a485a1b8cc7dd.html> [10] Yue Xiangrui. Bounded-Rollback Output Governance for Emotionally Safe Language Models. Zenodo. DOI: 10.5281/zenodo.22080966
-

